



LOST BOYS CYBER

THREAT INTELLIGENCE • MALWARE ANALYSIS • DETECTION ENGINEERING



Review intake draft: CVE-2026-11645 Google Chromium V8 Out-of-Bounds Read and Write Vulnerability

Vulnerability Report

Classification	TLP:CLEAR
Published	2026-06-10
Version	1.0
Author	Lost Boys Cyber
Report Type	Vulnerability Report

TLP:CLEAR | Lost Boys Cyber | Review intake draft: CVE-2026-11645 Google Chromium V8 Out-of-Bounds Read and Write Vulnerability - Vulnerability Report

Published: 2026-06-10 | TLP:CLEAR | Version: 1.0 | Author: Lost Boys Cyber

AI Generation: This report was generated with AI assistance and is provided for informational purposes only. All findings, IOCs, detection rules, hunting queries, attribution assessments, and recommendations must be independently reviewed and validated by a qualified security professional before operational use.

Table of Contents

1. Executive Summary
2. Intelligence Requirement
3. Source Review and Confidence
4. Key Findings
5. Threat Context
6. Detection and Hunting
7. Recommendations
8. References

1. Executive Summary

CVE-2026-11645 is a high-severity V8 memory-corruption vulnerability affecting Google Chrome and potentially other Chromium-derived browsers. Authoritative public sources reviewed for this intake agree that a remote attacker can trigger the flaw with a crafted HTML page and achieve arbitrary code execution inside the browser sandbox. Google has stated that exploitation exists in the wild, and CISA added the issue to the Known Exploited Vulnerabilities (KEV) Catalog on 2026-06-09.

The strongest supported business conclusion is that this is an urgent client-side patching problem with active exploitation pressure. Even though the public description only claims code execution inside the sandbox, browser zero-days are commonly valuable as initial-access or exploit-chain components because they can be paired with additional sandbox-escape or post-exploitation stages. Organizations should therefore treat vulnerable Chromium browsers on user workstations, privileged administrator endpoints, executive devices, kiosks, and contractor systems as high-priority exposure.

The public source set does not currently provide reliable indicators for a specific exploit kit, actor cluster, lure theme, or post-exploitation tooling tied uniquely to CVE-2026-11645. Detection should focus on three practical objectives: identify endpoints still running vulnerable browser builds, prioritize high-risk browsing populations for patch verification, and hunt for suspicious follow-on activity spawned from browser processes after user web activity.

A small but important source discrepancy exists in the versioning language. NVD models the issue as affecting Google Chrome versions prior to `149.0.7827.103`, while Google's June 8 stable release post says Chrome was updated to `149.0.7827.102/.103` for Windows and Mac and `149.0.7827.102` for Linux. Defenders should prefer the vendor-delivered stable update channel on each platform rather than relying on a single version string copied from a secondary database.

2. Intelligence Requirement

This review answered the following intelligence requirement: what is CVE-2026-11645, which environments are plausibly exposed, what is confirmed about exploitation, and what should defenders do immediately?

2.1 Vulnerability Metadata

Field	Value
CVE	`CVE-2026-11645`
Product / component	`Google Chrome / Chromium V8`
Vulnerability name	`Google Chromium V8 Out-of-Bounds Read and Write Vulnerability`
Weakness classification	`CWE-125: Out-of-bounds Read`; `CWE-787: Out-of-bounds Write`
Severity	`8.8 / HIGH`
CVSS v3.1 vector	`CVSS:3.1/AV:N/AC:L/PR:N/UI:R/S:U/C:H/I:H/A:H`
User interaction required	`Yes`
Publicly confirmed exploitation	`Yes - Google states an exploit exists in the wild; CISA KEV added 2026-06-09`
Affected Chrome versions	`Google Chrome prior to 149.0.7827.103` per NVD
Vendor-shipped fixed builds reviewed	`149.0.7827.102/.103` for Windows and Mac; `149.0.7827.102` for Linux per Google Chrome Releases
CISA KEV added	`2026-06-09`

CISA KEV due date	`2026-06-23`
Required action from CISA	`Apply mitigations per vendor instructions, follow applicable BOD 22-01 guidance for cloud services, or discontinue use if mitigations are unavailable.`

2.2 Key Intelligence Judgments

- 1. The issue is not speculative: Google and CISA both publicly treat CVE-2026-11645 as actively exploited.
- 2. The public exploit description supports remote delivery via a crafted HTML page, making standard user web browsing the likely exposure path.
- 3. The publicly documented impact stops at code execution inside the browser sandbox; however, that still represents serious operational risk because it can enable staging, credential theft facilitation, or chaining with additional browser or OS weaknesses.
- 4. Exposure is broader than Chrome alone because CISA explicitly warns that multiple browsers using Chromium could be affected until their maintainers ship corresponding updates.
- 5. Practical detection value is strongest in version-inventory enforcement and in hunting for suspicious child-process, download, or network behavior associated with browser-originated execution on recently unpatched systems.

3. Source Review and Confidence

Source	Contribution	Confidence
Google Chrome Releases stable desktop update (2026-06-08)	Primary vendor source for patch timing, shipped platform versions, bug class, reporter acknowledgement, and Google's statement that exploitation exists in the wild.	High
NVD CVE record / JSON 2.0 API	Corroborates the description, CVSS vector, affected version boundary, and KEV linkage.	High
CISA KEV JSON feed	Primary source for `dateAdded`, `dueDate`, CISA required action, and broader note that Chromium-derived browsers may also be affected.	High
CISA KEV alert (2026-06-09)	Confirms CISA publicly announced KEV addition based on evidence of active exploitation.	High
Microsoft Edge security release notes	Useful downstream-browser context showing Microsoft Edge Stable `149.0.4022.52` incorporates the latest Chromium project security updates.	Medium
Chromium issue tracker reference in the KEV feed notes	Suggests a corresponding upstream security case exists, but public detail remains restricted at review time.	Low

Confidence is high on the core facts: vulnerability class, affected component, exploitation status, and urgent patching requirement. Confidence is lower on exploit-chain specifics, threat-actor attribution, and exact downstream browser

remediation states because the reviewed public material intentionally withholds exploit details and does not provide a full technical root-cause write-up.

The main caveat is version normalization. Secondary databases and vendor release posts do not present the exact same patched-version string on every platform. This does not materially change the defensive recommendation: accept the latest stable vendor update for Chrome and rapidly validate that enterprise browsers have actually advanced beyond vulnerable builds.

4. Key Findings

4.1 Vulnerability Mechanics

The reviewed source set describes CVE-2026-11645 as an out-of-bounds read and write condition in the V8 JavaScript engine. NVD states that a remote attacker can exploit the issue via a crafted HTML page to execute arbitrary code inside the sandbox. Google labels the flaw as out-of-bounds memory access in V8, which is consistent with memory-corruption risk that can produce process compromise, instability, or controlled execution depending on exploit reliability.

4.2 Exploitation Status

Google explicitly states that an exploit for CVE-2026-11645 exists in the wild. CISA reinforced that assessment by adding the issue to the KEV Catalog on 2026-06-09 and assigning a remediation due date of 2026-06-23 for federal civilian agencies under BOD 22-01. Those two facts materially raise priority above a routine browser patch.

4.3 Exposure Surface

The strongest supported exposure pattern is user-driven browsing on endpoints running vulnerable Chrome or Chromium-derived browser builds. Environments at highest practical risk include:

Exposure Pattern	Why It Matters
Workstations used for routine web browsing	A crafted HTML page is the documented trigger path.
Privileged administrator endpoints	Browser compromise on admin systems can enable credential or session theft follow-on activity.
Executive, finance, HR, and help-desk devices	These users are frequent targets for phishing and targeted web lures.
Kiosks, labs, contractors, and intermittently managed assets	These populations often lag browser auto-updates and compliance enforcement.
Other Chromium-based browsers pending vendor backport confirmation	CISA notes that products such as Microsoft Edge and Opera may also be affected until maintainers ship updates.

4.4 Patch-State Interpretation

The reviewed source set supports the following operational interpretation:

- If an endpoint is still running a Chrome build earlier than the current June 8 stable security release, treat it as exposed.
- If a downstream Chromium-based browser has not yet consumed the latest Chromium security updates from its own vendor, treat it as potentially exposed until verified otherwise.
- If browser auto-update health is unknown, assume compliance gaps exist and verify by inventory rather than policy intent.

5. Threat Context

Public reporting is intentionally sparse, which is normal for actively exploited browser zero-days. The reviewed authoritative material does not name a threat actor, disclose exploit delivery infrastructure, or confirm whether the exploit was chained with a sandbox escape or privilege-escalation vulnerability. Accordingly, this report avoids over-claiming about full-device compromise pathways that are not directly documented in the current source set.

That said, the threat context is still serious. Browser zero-days remain attractive to both criminal and state-linked operators because they target a ubiquitous user-facing application, can be delivered through phishing or malicious web content, and may provide a foothold into higher-value systems when combined with social engineering, stolen sessions, or additional vulnerabilities. Even sandbox-constrained execution can be operationally useful for reconnaissance, staging, user deception, or exploit chaining.

5.1 Plausible Attack Scenarios

- 1. A user visits a malicious or compromised website serving exploit content tailored to vulnerable Chromium browsers.
- 2. A phishing email, chat lure, or social-media message drives the victim to an attacker-controlled page that triggers the V8 memory-corruption bug.
- 3. A threat actor uses the browser exploit as the first stage of a larger chain, then attempts credential theft, malicious download execution, or follow-on exploitation of local privilege or sandbox weaknesses.
- 4. A targeted campaign leverages unpatched contractor or unmanaged endpoints to compromise accounts that later reach internal SaaS, email, or VPN workflows.

5.2 ATT&CK Mapping Assessment

The currently supportable ATT&CK mapping is limited but not empty:

Technique	Name	Confidence	Rationale
T1189	Drive-by Compromise	Medium	Public descriptions state exploitation can occur through a crafted HTML page viewed by the victim.
T1203	Exploitation for Client Execution	Medium	The flaw affects client-side browser software and can yield attacker-controlled code execution inside the sandbox.

No higher-confidence mapping is assigned for post-exploitation, persistence, credential theft, or privilege escalation because the reviewed public materials do not document those later stages for CVE-2026-11645 specifically.

6. Detection and Hunting

There is no authoritative public exploit signature or IOC set unique to CVE-2026-11645 in the reviewed source set. Detection should therefore prioritize exposure identification, exploit-adjacent telemetry, and suspicious browser-originated follow-on activity.

6.1 Detection Logic Summary

Signal	Telemetry Source	Analytic Goal
Browser version inventory below the June 2026 patched baseline	EDR asset inventory, software inventory, MDM, package telemetry	Identify vulnerable endpoints requiring patch validation
Chromium browser child processes spawning shells, script hosts, LOLBins, or installers	EDR process telemetry	Surface possible post-exploitation or malicious follow-on execution
Browser-driven access to rare external domains followed by file download or script execution	Proxy, DNS, EDR network + process telemetry	Find suspicious lure-to-execution chains
Repeated browser crashes or instability on recently exposed systems	Endpoint crash telemetry, reliability monitoring, browser logs	Identify possible exploit attempts or exploit testing

Systems that missed browser update rollout after KEV publication	Patch-management and compliance telemetry	Prioritize remediation and executive reporting
--	---	--

6.2 Sigma Rule - Suspicious Child Processes from Chromium Browsers

```

title: Suspicious Child Process Spawned by Chromium-Based Browser
id: 1a9dbad5-3ef5-4b4a-b660-cve-2026-11645
status: experimental
description: Detects suspicious child processes launched from common Chromium-based browsers. This is not specific to CVE-2026-11645 but is useful for post-exploitation triage if a browser exploit chain leads to script or LOLBin execution.
logsource:
  category: process_creation
  product: windows
selection_parent:
  ParentImage|endswith:
    - '\\chrome.exe'
    - '\\msedge.exe'
    - '\\opera.exe'
    - '\\brave.exe'
selection_child:
  Image|endswith:
    - '\\cmd.exe'
    - '\\powershell.exe'
    - '\\pwsh.exe'
    - '\\wscript.exe'
    - '\\cscript.exe'
    - '\\mshta.exe'
    - '\\rundll32.exe'
    - '\\regsvr32.exe'
    - '\\curl.exe'
    - '\\bitsadmin.exe'
condition: selection_parent and selection_child
falsepositives:
  - Browser-based developer workflows
  - Enterprise SSO helper tooling
  - Approved browser extensions or updater edge cases
level: high

```

6.3 Exposure Inventory Query

```

// Inventory endpoints that may still be exposed to CVE-2026-11645.
let vulnerableFamilies = dynamic(["Google Chrome", "Microsoft Edge", "Opera", "Brave"]);
DeviceTvmSoftwareInventory
| where SoftwareName has_any (vulnerableFamilies)
| project DeviceName, SoftwareName, SoftwareVersion, EndOfSupportStatus, OSPlatform
| order by SoftwareName asc, DeviceName asc

```

Analyst note: adapt the vulnerable-version threshold per vendor. For Chrome, prioritize anything earlier than the currently deployed June 2026 stable security release. For downstream browsers, key off the vendor build that explicitly states it incorporates the latest Chromium project security updates.

6.4 Hunt Query - Browser to Suspicious Child Process Chain

```

let browserParents = dynamic(["chrome.exe", "msedge.exe", "opera.exe", "brave.exe"]);
let suspiciousChildren = dynamic(["cmd.exe", "powershell.exe", "pwsh.exe", "wscript.exe",
"cscript.exe", "mshta.exe", "rundll32.exe", "regsvr32.exe", "curl.exe", "bitsadmin.exe"]);
DeviceProcessEvents
| where Timestamp > ago(30d)
| where InitiatingProcessFileName in~ (browserParents)
| where FileName in~ (suspiciousChildren)
| project Timestamp, DeviceName, InitiatingProcessAccountName, InitiatingProcessFileName,
InitiatingProcessCommandLine, FileName, ProcessCommandLine, SHA1

```

| order by Timestamp desc

6.5 Hunt Questions

- 1. Which endpoints still show vulnerable Chrome or Chromium-derived browser versions after the 2026-06-09 KEV addition?
- 2. Which high-risk users browsed from those endpoints after patch publication?
- 3. Do vulnerable endpoints show browser-originated launches of shells, script hosts, or download utilities?
- 4. Are there suspicious downloads, archive extractions, or authentication anomalies shortly after browsing activity on affected systems?
- 5. Did any asset groups systematically fail browser auto-update, indicating a fleet-wide compliance issue rather than isolated lag?

7. Recommendations

7.1 Immediate Actions

Priority	Owner	Action
Critical	Platform / Endpoint Engineering	Force-update Google Chrome to the latest vendor-provided stable build on all supported platforms immediately.
Critical	Platform / Endpoint Engineering	Validate browser versions through inventory and EDR telemetry rather than assuming auto-update succeeded.
High	Security Operations	Prioritize review of browser-originated child-process, download, and suspicious network activity from endpoints that remained unpatched after 2026-06-09.
High	IAM / Security	Review risky authentication activity involving users on browsers that lagged the patch window, especially privileged and executive populations.
High	Vulnerability Management	Track KEV remediation against the 2026-06-23 due date and treat Chromium-derived browsers as potentially exposed until each vendor's patched release is confirmed.
Medium	Security Awareness / IT	Warn users not to defer browser restarts when prompted for updates and to report suspicious web prompts or unexpected downloads.

7.2 Strategic Actions

- 1. Add browser-version compliance to routine executive vulnerability reporting, especially for KEV-listed client software.
- 2. Treat browser auto-update health as a monitored control with measurable SLAs, not a best-effort convenience feature.
- 3. Expand detections for browser-originated child-process execution, suspicious downloads, and identity events that follow risky browsing sessions.
- 4. Ensure high-value users and admin workstations are prioritized for rapid browser patch verification and, where feasible, browser isolation or stricter web controls.

8. References

- 1. Google Chrome Releases, `Stable Channel Update for Desktop`, 2026-06-08, https://chromereleases.googleblog.com/2026/06/stable-channel-update-for-desktop_0153744567.html
- 2. NVD, `CVE-2026-11645`, <https://nvd.nist.gov/vuln/detail/CVE-2026-11645>
- 3. NVD JSON 2.0 API, `CVE-2026-11645`, <https://services.nvd.nist.gov/rest/json/cves/2.0?cveId=CVE-2026-11645>
- 4. CISA Known Exploited Vulnerabilities Catalog, `CVE-2026-11645`, https://www.cisa.gov/known-exploited-vulnerabilities-catalog?search_api_fulltext=CVE-2026-11645
- 5. CISA KEV JSON feed, https://www.cisa.gov/sites/default/files/feeds/known_exploited_vulnerabilities.json
- 6. CISA Alert, `CISA Adds Three Known Exploited Vulnerabilities to Catalog`, 2026-06-09, <https://www.cisa.gov/news-events/alerts/2026/06/09/cisa-adds-three-known-exploited-vulnerabilities-catalog>
- 7. Microsoft Learn, `Release notes for Microsoft Edge Security Updates`, <https://learn.microsoft.com/en-us/deployedge/microsoft-edge-relnotes-security>